

Ethical Hacking Internship Batch 01 — Secure Dev Labs

Muhammad Saad



Week 03 – Web Vulnerability Validation

Muhammad Saad

What is SQLi

Imagine a website has a login form where you enter your username and password. Behind the scenes, the website checks the database using a command written in SQL.

Normally the website asks the database something like:

“Check if this username and password exist.”

But in SQL Injection (SQLi), a hacker types special database commands into the input box instead of normal text.

The hacker tricks the website into running their own database commands. This can allow them to:

- Log in without a password
- See private data (users, emails, passwords)
- Change or delete data
- Sometimes take control of the whole database

Instead of typing a normal username, a hacker types something like: ' OR '1'='1

What is In-Band SQLi ?

In this attack, the hacker sends the SQL injection and receives the results through the same communication channel (the same webpage response)

Error-Based SQL Injection

Error-based SQLi uses database error messages to get information.

If the website shows database errors, the attacker can purposely cause errors and read useful data from them.

Example concept:

Input: ' OR 1=1 --

Union-Based SQLi

Union-based SQL injection uses the SQL UNION operator to combine results from multiple queries.

Example idea:

SELECT name FROM products UNION SELECT username FROM users

What is Blind SQLi ?

Blind SQL Injection happens when a website is vulnerable to SQL injection but does not show database errors or data directly. So the attacker cannot see the database results, but they can still figure out the data by observing the website's behavior (like page changes or response time).

- The hacker asks the database true/false questions and watches how the website responds.
- Example logic: Is the first letter of the database name = 'a' ?
- If true → page behaves normally & If false → page behaves differently

Boolean-Based SQLi

This type uses TRUE or FALSE conditions where the attacker injects a condition and watches how the webpage changes.

Normal query: `SELECT * FROM users WHERE id = 1`

Time-Based SQL Injection

Error-based SQLi uses database error messages to get information

If the website shows database errors, the attacker can purposely cause errors and read useful data from them.

Example concept: Input: ' OR 1=1 -

What is Cross-Site Scripting (XSS)?

XSS stands for Cross-Site Scripting. It is a web security vulnerability that allows an attacker to inject malicious scripts (usually JavaScript) into a website that other users visit.

When a website does not properly check or sanitize user input, an attacker can insert malicious code. That code then runs in the browser of other users, not on the attacker's computer.

Example:

Imagine a comment box on a website:

Normal user comment:

This article is helpful!

Attacker comment:

```
<script>alert('You are Haked')</script>
```

If the website does not filter this code, the script runs in every visitor's browser who views the comment.

Stored XSS (Persistent XSS)

Stored XSS happens when the malicious script is permanently saved on the target website's server (database, comment section, forum post, user profile, etc.).

How it works

- Attacker submits a malicious script (e.g., in a comment box)
- The website stores it in the database
- Every user who views that page unknowingly runs the script in their browser

Reflected XSS

Reflected XSS happens when the malicious script is not stored, but instead is immediately reflected back by the server in the response.

How it works

- **Attacker sends a malicious link to a victim**
- **Victim clicks the link**
- **The server includes the script in the response page**
- **The victim's browser executes it**

“Best of Luck”



- *Muhammad Saad*